

Cybersecurity Policy and Procedures

Policy applicable to:

Copia	OC	Vertium	Chester
Yes	Yes	Yes	Yes

Version control:

Approved by board on:	26 February 2024
Approved by:	Board
Policy implementation:	IT Department
Other related policies	Business Continuity Management/Disaster Recovery Plan Employment Policies
Key related legislation/guides:	ASIC - Cyber resilience good practices www.business.gov.au/Risk-management/Cyber-Security/Creating-a-cyber-security-policy-for-your-business

Contents

1	Purpose	1
1.1	Mandate and Commitment	1
1.2	Staff training and awareness	1
2	IT architecture	2
2.1	Network protection	3
2.2	Desktop and laptop management	4
2.3	Email management	5
2.4	Data redundancy.....	5
2.5	Copiers/scanners	5
2.6	Software as a service (SAAS).....	5
2.7	Cyber-attacks	6
2.8	Staff obligations	6
3	Appendix -1	7
3.1	Rules for staff.....	7
3.1.1	Passwords	7
3.1.2	CIPL's IT network.....	7
3.1.3	SAAS Passwords	8
3.2	How to protect against cyber criminals.....	8
3.2.1	Fraud	8
3.2.2	Blackmail & coercion.....	10

1 Purpose

To set out a framework for managing cybersecurity by Copia Investment Partners Ltd (**CIPL**) and related companies.

Cyber-attacks are aimed at electronic information management systems with one or more goals of illegally obtaining company or client information and valuables or to cause damage to IT infrastructure. These attacks may be made by:

unauthorised access or hacking – when someone gains access to a computer or device without permission

malware – malicious software (such as viruses, trojans and spyware) which monitors user activity or may cause damage to computer

ransomware - which is a form of malware where information on a computer is encrypted and the criminal blackmails the user to unlock the information

denial of service attacks – which floods a computer or website with data, causing it to overload and prevent it from functioning properly

phishing emails and other electronic messages - which trick users into giving out their personal or financial details. Phishing messages often pretend to come from legitimate businesses, such as banks or telecommunications providers. This type of attack may be referred to as behavioural engineering.

identity theft - when a criminal uses information stolen from a user to steal money from the user or to commit crimes in the user's name.

Cybersecurity is the process of protecting information by preventing, detecting and responding to cyber-attacks. There has been a growing number and increased level of sophistication of cyber-attacks experienced worldwide over the past decade. The risk of loss or damage is now considered to be a material risk. Given our level of dependency on information technology and electronic communications this risk requires a dedicated management program.

By implementing this program CIPL intends to build its cyber resilience. Cyber resilience is the ability to prepare for, respond to and recover from a cyber-attack. Resilience is more than just preventing or responding to an attack—it is also the ability to operate during, and to adapt and recover, from such an event. Cyber resilience is the intended outcome of cyber risk management and cybersecurity measures. A resilience-based approach to cyber-attacks is vital for better adapting to change, reducing exposure to risk, and learning from incidents when they occur.

CIPL maintains Cyber insurance. This insurance provides an amount on assessment of damages or losses incurred by a cybercrime event. This program aims to reduced likelihood of such an event occurring.

1.1 Mandate and Commitment

This program is supported by the Board. This support is evidenced by the Board adopting the program and by delegating authority to the Chief Financial Officer & Operations Officer (**CFOO**) to implement, maintain and report on the risks and effectiveness of the program to the Board.

1.2 Staff training and awareness

All staff will receive training on CIPL's cybersecurity procedures.

2 IT architecture

IT architecture is the composite of IT hardware components, software and services which are used to store and process electronic records.

The CFOO is responsible for the IT systems used by CIPL. In managing these systems, the CFOO is assisted by an IT Consultant who is responsible for recommending and implementing approved changes to the IT architecture.

The following elements shall be maintained as part of the IT architecture:

1. **IT infrastructure map:** this is a diagram showing all hardware components of the IT environment.
2. **Software register:** this is register of all software currently deployed by CIPL. It includes the following information:
 - Software name
 - Version release date
 - Licence details
 - Number of licences held
 - Number of iterations deployed
3. **IT assets register:** this is a register of all hardware assets currently deployed by CIPL. This includes all network components, desktops, laptops, mobile devices and peripheral devices. It also includes any device that may be connected to the network (ethernet or Wi-Fi) referred to as the '*Internet of Things*' - such as TVs, AV-receivers and smart fridges – and IP cameras.
4. **Switch port register:** This is a register of all cabled wall sockets which are to be uniquely numbered. These sockets are to be recorded against the patch panel number that they are cabled to.
5. **Wi-Fi connections:** This is a register of all devices connected to the Wi-Fi network having been provided with either a Guest or CIPL logon on. This register shall record the name of each device, its MAC address, and time and duration of each connected session.
6. **User listing:** This is a record of all authorised network users. It includes the users' names, authorisation for systems access, drives they are permitted to access and software as a service ("SAAS") applications they may access. It also includes a record of user de-listings and confirmation that system accesses have been closed on staff terminations.
7. **Service providers:** This is a list of all SAAS systems used by CIPL. It identifies the CIPL owner of the SAAS service, the modules available via the service and the contract renewal date.

In maintaining the IT architecture, the following principles will be applied:

- a) Where possible resource silos will be consolidated and centralised into a single data silo. This includes ensuring that all data is stored on a server and not isolated in local drives in either desktop or laptop computers. Local storage will be permitted for data processing requirements or remoteness from the network, but in these cases the data must be replicated to the network at the earliest opportunity.

- b) A single system profile will be used for all desktop and laptop computers. This includes using the same version of the desktop operating system and software applications.
- c) Excess redundancy – electronic records will be protected by multiple levels of redundancy including RAID, onsite and offsite data backups.
- d) All software will be patched to the latest version as soon as practicably possible. Legacy software will only be permitted if required to access unique file formats. Any legacy software will be annotated as such in the Software register.
- e) Applying password protection to all devices, which includes changing default 'Admin' logons and passwords from default settings.

The CFOO and IT Consultant shall review the IT architecture at least annually. The purpose of this review is to:

- 1. Identify whether the IT architecture is adequate for the needs of CIPL
- 2. Identify any new capital expenditure that should be budgeted for the following financial year
- 3. Confirm that all software licences are accounted for and utilised
- 4. Confirm that all IT assets are within CIPL's control
- 5. Confirm that all network ports in use and Wi-Fi connected devices have been properly authorised
- 6. Confirm only authorised users have accessed IT resources.

The CFOO shall document these reviews. These documents will be presented to the Risk & Compliance Committee.

2.1 Network protection

The IT Consultant is responsible for maintaining and making recommendations on improving the cyber-resilience of the CIPL IT network.

All World Wide Web (WWW) connections and network traffic is centrally managed through a firewalled router (Watchguard).

The IT Consultant will scan all router ports and shall close all unused ports.

All devices connected to the network - albeit by ethernet, Wi-Fi or remote access – will be identified and recorded.

All authorised devices will be recorded in the IT assets register and/or Wi-Fi connections register.

A user may only be admitted access to the network on completion of a "*User Access Form*". This form must be signed by the CFOO. Once admitted, the user shall be recorded on the user listing. Any changes to a user's systems access must be approved by a further completed form.

Access shall be granted under the principle of "*less privilege*", i.e., each user will receive the minimum rights and access to resources needed for their business functions.

Network access is protected by two factor authentication, requiring users to confirm their identities by another device or application before they may access the network or change their credentials.

Once a user leaves CIPL then their access must be terminated within 12 hours of leaving the premises. The IT Consultant is to be advised of all staff terminations in advance.

All users to the network will be managed by Microsoft Active Directory (Active Directory) on the server. Only the IT Consultant will have ability to add, vary and remove users from the network. The IT Consultant will set security policies within Active Directory.

Active Directory has been set to require users to renew their passwords every 90 days. Further details on password settings are set out below.

The IT Consultant has configured Microsoft Active Directory to time out further logon attempts on a time graduated basis if more than 5 consecutive logon attempts fail within 5 minutes.

Remote access will be enabled by a virtual private network ("VPN"). VPN access will only be provided on a restricted basis to staff on as needs basis. All VPN credentials will be managed by WatchGuard.

Staff may connect their own mobile phone and tablet devices to the Wi-Fi. Staff may only do so using their network logon credentials. As a condition of employment, all staff must on request submit their mobile or tablet device for review by the IT Consultant to identify whether any file accessing applications have been activated on the device.

Guests to CIPL will be provided with a Guest Login. All guests must be recorded in a register maintained by Reception and the logon shall be provided by the IT Consultant. A guest login password will be unique to the particular guest and it shall be removed from authorisation list once the guest leaves a CIPL Office. Guests will not be provided access to the file server, unless specially authorised by the CFOO.

The network operating system software has been configured to automatically download and install operating system patches.

An anti-virus application (Avast) has been loaded on server, which provides real time file save scans and daily full server scans. This application is automatically patched and updated for new virus listings.

The Wi-Fi has been secured by:

- Hiding the Service Set Identifier (SSID)
- Approving and recording the MAC addresses of all connecting devices
- Applying WPA2

The network will be tested by an ethical hacking exercise at least once every 48 months.

2.2 Desktop and laptop management

Only CIPL owned and provisioned computer may access the file server.

A standard user profile is maintained on the server. All computers have been updated to Window 10 OS and newer hardware is being configured for Windows 11 OS if possible. Office software is provided via Microsoft Office 365. Both the operating systems and office software are configured to be automatically patched on release.

Software not included in the standard profile requires written approval from the CFOO.

All computers are configured to require logon if the computer is unused for more than 20 minutes.

Anti-virus has been loaded on each computer (Avast), which provides real time file save scans. This application is automatically patched and updated for new virus listings. The anti-virus provides real time checks on URLs accessed by users via browsers or embedded links.

The anti-virus has been configured to scan all devices connected to a computer before allowing file transfers (e.g., USB connected devices).

On decommissioning of either a desktop or laptop computer, the IT Consultant is required to ensure that the hard drive is removed and destroyed before the machine is disposed.

2.3 Email management

CIPL has outsourced its email server to Microsoft.

Security configurations have been based on Microsoft recommended settings.

CIPL has subscribed to Office 365 Enterprise E3. This provides '*Legal Hold*', which preserves copies of all sent and received emails, even if deleted from an account by a user.

CIPL has also subscribed to Microsoft Office 365 Advanced Threat Protection, which provides an additional protective layer for Office suite products and emails (including additional attachment scans and URL checks).

2.4 Data redundancy

All work files are stored on the CIPL server. These are replicated in real time to a corporate OneDrive account maintained under the Office 365 Enterprise E3 contract. Staff may use their credentials to access files stored on the OneDrive account.

The server has been configured for RAID 6, which allows three hard disk failures before data loss.

The server has been provided by DELL Corporation and is managed under a 4-hour response time agreement with DELL. Failed disks are automatically reported by the server to IT Consultant.

All files are backed up to a local NAS device (QNAPS) daily. The backup is then mirrored to another NAS device located in the Sydney office.

Sydney office files are saved directly to the server on local save.

All communications between the Melbourne and Sydney offices are encrypted, using SSL AES 256bit encryption.

CIPL maintains a Business Continuity Management and Disaster Recovery Plan (**Plan**). Under the Plan the disaster recovery procedures are tested at least annually. These tests involve a restore from backed up data.

2.5 Copiers/scanners

Access to the photocopier requires credentials for access.

Scanned documents may only be saved to a Drive on the network.

On decommissioning, the IT Consultant is required to confirm with the lessor that the hard drive of the photocopier is wiped before being returned to ensure all temporary files of scanned documents are deleted.

2.6 Software as a service (SAAS)

Applications are increasingly being provided as cloud-based software services than as applications executed on either a server or client computer.

It is possible that these services may they hold confidential commercial or private information concerning clients or staff or can be linked into data repositories held by CIPL via APIs.

SAAS arrangements may open CIPL to cyber risk through loss of commercial/private information or by allowing unauthorised access to our data repositories.

A SAAS arrangement will only be permitted on the written authority of the CFOO. This permission will only be granted once the SAAS arrangement has been reviewed by the IT Consultant.

In reviewing a SAAS arrangement, the IT Consultant will consider the cyber resilience of the provider, including how data between CIPL and the SAAS provider is secured.

Depending on the nature of the SAAS, it may be necessary to apply the standards set out in the Outsourcing Policy or to consult with the Risk & Compliance Manager.

2.7 Cyber-attacks

Actual and potential cyber-attacks are to be treated as incidents must therefore be recorded in the Issues Register maintained on CRS-Certus and reported to the board of CIPL.

Cyber-attacks may be identified by the IT Consultant or by staff (see Appendix 1).

Once an incident has been reported, the IT Consultant will:

Identify and assess

- Find the initial cause of the incident and assess the impact so it may be quickly contained.
- Determine the impact the cyber incident has had on CIPL and the effects to its business and assets if not immediately contained.

Respond

- Limit further damage of the cyber incident by isolating the affected systems. If necessary, disconnecting computers from the network to stop the threat from spreading.
- Eliminate the problem with the removal of the threat.
- Recover from the incident by repairing and restoring the IT systems to business as usual.

Review

- Identify if any systems and / or processes need improving and propose those changes to the CFOO for implementation.
- Evaluate how the incident affected the business before and after, and any lessons learnt.
- Update this policy based on the lessons learnt.

2.8 Staff obligations

All staff are required to follow the requirements of this Policy. Breach of this Policy by a staff member could result in disciplinary action by management.

Staff are required to follow the Rules for Cyber security provided in Appendix 1.

3 Appendix -1

3.1 Rules for staff

IT assets are provided for business purposes. Limited private use of these assets is permitted. Staff who abuse these rights or otherwise fail to adhere to the following rules will be subject to censure and, in severe cases, dismissal.

Intellectual property rights: CIPL retains ownership of all electronic and hardcopy records and data produced by the business (intellectual property). Staff may not copy, disseminate or retain intellectual property unless permitted for business purposes. On cessation of employment all intellectual property must be either returned to CIPL or destroyed.

Email: Email has been provided for business use. Limited private use is acceptable. However, staff must be cautious when using email (see below). Personal email usage is restricted – please refer to *2.5 Technology & Communications, Employment Policies*.

Office equipment: All CIPL provided hardware, including desktop computers and laptops, are the property of CIPL. Limited and reasonable personal use of these assets is permitted. However, staff must not:

1. permit another person to use their assigned computer unless that person is supervised at all times by the assigned owner
2. change either the operating system or the applications on a CIPL computer or laptop.
3. attach memory sticks or other memory storage devices that have not been supplied by CIPL to the computer without the express approval of the CFOO
4. leave equipment unattended in public places or fail to take reasonable measures to protection equipment (e.g., laptops must be boarded as hand luggage on flights).

You must:

1. Sign out of your account if you are going to be away from your computer/laptop for more than 15 minutes.
2. Logoff at the end of the day and shut down your computer/laptop
3. If you have a laptop, it must be set up to hibernate on lid closure and require a logon on awakening.

If you have CIPL supplied mobile phone, you must:

1. Turn off Bluetooth until required to attach a device. On completion of the task you must turn off the Bluetooth.
2. Not enable the phone as a mobile hotspot, unless required to attach a device. On completion of the task you must turn off the tethering or PAM.

3.1.1 Passwords

Passwords are required for both CIPL's network and SAAS applications.

3.1.2 CIPL's IT network

Staff must keep their passwords confidential. Under no circumstances are passwords to be shared.

Passwords are managed under security policies set on the server.

These emails may appear to come from a legitimate source. The email addresses may be subtly changed from the hoaxed sender's address, or the fraudster may simply over stamp their address with the hoaxed sender's address. Checking the details of the email header may uncover the hoax, but in sophisticated frauds the email may be even sent from the hoaxed senders email account.

Phishing emails may be customized to the receiver by using your name, providing address details or billing account information. Customized phished emails are very difficult to distinguish from the hoaxed sender's actual communications.

Phishing emails often include URLs which you are requested to visit. These may be embedded in an attachment to the email. The URLs are typically masked to look as if they are from the legitimate source. These will take you to a faked website where you may be asked for personal information or transfer money.

Text ("SMS") messages may also be used by fraudsters. These will appear to have been sent from a legitimate source, requesting you to respond with details or to visit a website.

Fraudsters may also call by telephone and pretend they are from a service provider or client. These calls are typically aimed at gathering further information for a future fraud attempt but may involve a request to pay money or electronically transfer stored value cards to an account as payment for bogus services. Typically, the caller will claim urgency and pressure for quick action to resolve an alleged problem.

Fraudsters may also surreptitiously load malware onto your computer. Spyware may collect information from your system and record information as you navigate and use your system. This information is feed back to the fraudster who may use it to commit a fraud.

3.2.1.1 What to do:

Do not trust email.

Only share your email address with people who need to know it. Do not published your email address on the internet or share it on social media websites.

If you are asked to provide sensitive or commercial information by an email request, confirm the authenticity of the request by another means such as calling the sender using a telephone number found from another source.

Do not click on any URLs in an email or an attachment to an email without first checking the domain name of the link by right mouse clicking on it. If the domain name is not the same as the hoaxed provider's name, do not click on the link.

Do not send any sensitive information, including commercial documents, by email. If you need to, use a SSH File Transfer Protocol service which encrypts communications and requires end user authentication. The IT Consultant may assist you to set up a secure file transfer service for communicating with parties outside of the Copia network.

Ensure that all email and attachments are virus inspected prior to downloading or saving.

Do not open any emails that look suspicious (e.g., unknown sender, unusual topic header).

Do not respond to SMSs requesting you to call a number or follow a URL in a text message. If you need to, find another number for the sender and call that.

Do not provide sensitive or commercial information to telephone callers. If the caller is a client, advise them that you will call back, then call on the phone number held on file.

Be cautious about the websites you visit. It is possible to download malware from websites, even if you don't do anything other than visit the site. Never click on pop-up browser windows. If you see a pop-up, immediately close your browser.

If your computer seems unusually sluggish, or applications close unexpectedly, call the IT Consultant. You may have malware on your system.

Never make a payment to a person who has made an unsolicited phone call.

Never divulge personal information that may identify you on social media. Do not divulge your birth date, residential address, phone numbers or email address.

3.2.2 Blackmail & coercion

Blackmail and coercion are often combined by criminals.

Fraudsters may send emails threatening to release incriminating information about a person unless they pay money into an account. Most of these types of threats are speculative and rely on the users' fear or guilt.

Ransomware is a form of blackmail where a virus encrypts hard drives and the blackmailer demands money to decrypt the drives.

3.2.2.1 What to do:

Do not respond to unsolicited, threatening, emails.

If your computer shows signs of being encrypted, or you have a message that demands payment for repairing your computer:

- Turn the power off
- Pull out your ethernet cable (if the computer is cabled to the network)
- Call the IT Consultant.

Cyber threats may not be obvious. The following may be symptomatic of a cyber-attack:

- accounts and your network cannot be accessed
- passwords no longer work
- data is missing or altered
- your hard drive runs out of memory
- your computer keeps crashing
- your customers receive spam from your business account
- you receive numerous pop-up ads

If you have any reason to suspect that you or Copia have been compromised by a cyber-attack, please immediately contact either the Chief Financial Officer, Compliance Manager and IT Consultant.

-- End of document --